

Melhorias prioritarias do Programa de Embaixadores Bryza

Riscos atuais, modificacoes recomendadas, criterios de aceite e ordem de implementacao

CONCLUSAO PRINCIPAL A base do programa e consistente, mas o sistema nao deve ser escalado antes de corrigir o provisionamento de acesso, o momento de calculo das comissoes, a autorizacao do portal e a aplicacao da ativacao mensal.

Estado verificado em 22/07/2026	Quantidade
Embaixadores cadastrados	3
Candidatos automaticos	0
Comissoes geradas	0
Pedidos com snapshot de comissao	0
Planos ativos sem valid_to	2

Este e o melhor momento para corrigir a arquitetura: ainda nao existe historico financeiro relevante a migrar.

1. Mapa executivo de prioridades

Prioridade	Modificacao	Risco principal	Resultado esperado
P0	Provisionamento unico e idempotente	Ativo sem login ou cadastro orfao	Candidato vira usuario sem duplicidade
P0	Congelamento financeiro do pedido	Comissao divergir da venda final	Valor sempre reproduzivel
P0	Autorizacao real no portal	Sessao antiga acessar dados via service_role	Bloqueio efetivo e menor exposicao
P0	Ativacao mensal aplicada	Regra comercial existir apenas na tela	Qualificacao calculada e auditada
P1	Atribuicao e cookie coerentes	Disputa sobre quem recebe a venda	Uma politica unica e previsivel
P1	Pix, pagamentos e estornos	Repasse incorreto ou sem conciliacao	Lotes e ledger financeiro
P1	Versionamento de planos e base	Planos ativos duplicados e calculo ambiguo	Vigencia e calculo consistentes
P1	Testes financeiros em CI	Regressoes silenciosas	Mudancas verificadas automaticamente
P2	Consentimento, antifraude e observabilidade	Abuso e risco de privacidade	Operacao segura e mensuravel
P2	Rede dinamica e UX	Produto nao acompanhar configuracao	Portal escalavel e compreensivel

RECOMENDACAO Tratar os itens P0 como bloqueadores de crescimento. Os itens P1 devem entrar imediatamente depois, antes de aumentar volume de vendas ou quantidade de embaixadores.

PO - CRITICA

2. Fluxo unico de ativacao e provisionamento

Problema atual

- A compra publica cria um registro pendente em ambassadors, com codigo Bryza e user_id vazio.
- Quando o administrador encontra o mesmo CPF, a API retorna sucesso e encerra o processo, sem criar conta Auth.
- Alterar o status para ativo nao cria usuario, senha ou profile.
- Assim, o banco pode representar como ativo alguem que nao consegue acessar o painel.

Modificacoes necessarias

- 1 Separar status comercial de status de provisionamento: candidate, provisioning, provisioning_failed, provisioned e access_blocked.
- 2 Criar a acao administrativa Provisionar acesso, capaz de continuar a partir de um candidato existente.
- 3 Validar CPF, telefone, e-mail, plano, patrocinador e consentimento antes de criar a conta.
- 4 Criar usuario Auth, profile e vinculo ambassadors.user_id antes de permitir status ativo.
- 5 Tornar todo o processo idempotente por candidato/CPF e retomavel depois de falhas.
- 6 Adicionar protecao no banco: status ativo exige user_id nao nulo e profile compativel.

CRITERIO DE ACEITE Um comprador que recebeu codigo pode ser provisionado sem recadastro, duplicidade ou intervencao manual no banco.

Evidencias tecnicas

Checkout automatico: migration 20260718044648, linhas 343-359. Retorno antecipado por CPF: src/app/api/embaixadores/route.ts, linhas 123-127.
Alteracao de status: src/app/embaixadores/actions.ts, linhas 396-438.

3. Provisionamento recuperavel, sem exclusao compensatoria

A API insere o embaixador antes de criar a conta Auth. Se Auth ou profile falhar, tenta apagar o registro. Entretanto, outro trigger proibe exclusao fisica. O rollback pode falhar e deixar um cadastro orfao.

- Nao usar DELETE como rollback de provisionamento.
- Registrar provisioning_failed com etapa e erro tecnico sanitizado.
- Permitir retomar o processo de forma segura.
- Criar uma fila administrativa de acessos com falha.
- Executar reconciliacao periodica: embaixador sem user_id, Auth sem profile e profile sem embaixador.

CRITERIO DE ACEITE Nenhuma falha de Auth deve deixar um cadastro que pareca concluido ou exija limpeza manual.

PO -
FINANCEIRA

4. Gerar comissao somente com pedido congelado

MAIOR RISCO FINANCEIRO As comissoes nascem no AFTER INSERT, enquanto pedidos em aguardando_preparacao ainda podem ser editados. O total pode mudar e a comissao permanecer com o valor antigo.

Arquitetura recomendada

- 1 Adicionar commission_locked_at e um estado explicito de congelamento financeiro.
- 2 Antes do congelamento, mostrar apenas uma previsao de ganho, sem criar registro financeiro definitivo.
- 3 Gerar snapshots e comissoes quando o pedido sair da fase editavel, em uma unica transacao.
- 4 Depois do congelamento, bloquear mudancas em itens, quantidade, preco, descontos, total, indicador e plano.
- 5 Se a operacao precisar corrigir um pedido congelado, usar uma RPC auditada que gere versao ou estorno, nunca edicao silenciosa.

Alternativa aceitavel

Caso a Bryza precise gerar comissao na conversao do agendamento, toda edicao posterior deve passar por uma RPC que recalcula pedido, base, snapshots e comissoes atomicamente. A edicao deve ser proibida depois da confirmacao logistica/financeira.

CRITERIO DE ACEITE Toda commission_amount pode ser reproduzida a partir dos itens, descontos, base e plano congelados naquele pedido.

Evidencias: trigger de geracao em migration 20260718044648, linhas 495-508; edicao de pedidos em src/services/pedidos.ts, linhas 153-180; sincronismo atual altera apenas status nas linhas 510-522.

5. Implementar a ativacao mensal de R\$ 79

A configuracao vigente exige R\$ 79 em compras pessoais e dez dias de tolerancia, mas o motor de comissoes verifica somente status cadastral ativo. A movimentacao mensal nao participa do calculo.

Decisoes comerciais obrigatorias

- A qualificacao vale na data da venda, entrega ou liberacao da comissao?
- O valor nao qualificado e perdido, retido ou liberado depois da regularizacao?
- Compras canceladas e estornadas deixam de contar?
- A compra precisa estar entregue e paga?
- A qualificacao afeta nivel direto, niveis indiretos ou ambos?

Estrutura sugerida

Campo	Funcao
ambassador_id + reference_month	Chave da competencia
required_amount / qualified_amount	Meta e valor apurado
status	em_apuracao, qualificado, em_tolerancia, nao_qualificado, override
qualified_at / grace_expires_at	Datas de qualificacao e tolerancia
override_by / override_reason	Excecao administrativa auditada

REGRA RECOMENDADA Criar a comissao como retida_qualificacao. Liberar durante a tolerancia quando houver regularizacao; nao apagar registros financeiros.

P0 -
SEGURANCA

6. Remover service_role do fluxo comum do portal

Algumas server actions validam apenas a existencia de uma sessao e depois consultam o banco com credencial administrativa, que ignora RLS. Minha Rede tambem retorna telefones completos dos descendentes.

Modificacoes necessarias

- 1 Criar requireActiveAmbassador() e usa-lo em todas as server actions do portal.
- 2 Validar profile.role, profile.ativo, must_change_password, ambassadors.status e correspondencia de user_id.
- 3 Trocar consultas administrativas por RLS de propriedade ou RPCs que derivam o embaixador de auth.uid().
- 4 Nunca aceitar ambassador_id do navegador para consultas pessoais.
- 5 Mascarar telefone da rede ou exigir consentimento para disponibilizar contato.
- 6 Revogar sessoes ao bloquear/inativar e validar session_id em operacoes financeiras sensiveis.

RISCO Uma sessao antiga pode continuar autenticada. Se a server action usa service_role depois de validar apenas user, o bloqueio cadastral pode nao impedir a consulta.

Referencia oficial: Supabase Service keys bypass RLS; Supabase User sessions e validacao de session_id. Evidencia local: src/app/embaixador/actions.ts, linhas 8-14 e 71-133.

P1 - ALTA

7. Definir uma unica politica de atribuicao

Hoje coexistem uma visita/cookie de 30 dias e uma primeira atribuicao bloqueada por tempo indeterminado. Um clique recente pode autorizar a compra, mas o valor continuar com o primeiro indicador historico.

Politicas possiveis

Modelo	Vantagem	Risco
First-touch 30 dias	Valoriza aquisicao inicial	Pode ignorar influencia recente
Last-touch 30 dias	Valoriza o ultimo contato	Facilita disputa e roubo de atribuicao
Permanente	Rede simples e previsivel	Janela de 30 dias perde sentido
Congela apos 1a compra paga	Equilibra aquisicao e rede	Exige estado adicional

RECOMENDACAO Usar first-touch ate a primeira compra entregue e paga. Depois, congelar o patrocinador do novo embaixador e aplicar uma regra explicita para compras futuras do cliente.

- Definir comportamento quando o indicador original estiver inativo.
- Definir solicitacao de troca pelo cliente.
- Limitar reatribuicao a estados nao terminais e exigir motivo.
- Registrar historico de cada mudanca de atribuicao.

8. Sincronizar cookie e janela configurada

- Ler `referral_attribution_days` antes de criar o cookie.
- Usar o mesmo prazo em `expires_at`, `maxAge` e validacao do banco.
- Tornar `REFERRAL_COOKIE_SECRET` obrigatorio e remover fallback para `service_role`.
- Versionar o payload do cookie.
- Nao emitir cookie utilizavel quando a visita nao foi gravada.

Evidencias: `src/lib/referral/cookie.ts`, linhas 29-41; `src/app/r/[code]/route.ts`, linhas 87-116; validacao dinamica do banco na migration 20260718044648, linhas 262-276.

P1 -
FINANCEIRA

9. Aplicar corretamente a base de comissao

A interface aceita valor final, bruto ou liquido, mas o motor nao possui estrategias diferentes para essas opcoes. Enquanto isso nao estiver implementado, a configuracao transmite uma capacidade que o calculo nao entrega.

Base	Definicao recomendada
valor_bruto	Soma de preco x quantidade antes de descontos
valor_final	Valor efetivamente cobrado do cliente
valor_liquido	Valor final menos componentes explicitamente excluidos da comissao

- Criar uma unica funcao de calculo da base.
- Usa-la em checkout publico, pedido administrativo, conversao e testes.
- Congelar valor bruto, descontos elegiveis, itens nao comissionaveis e base final.
- Ate a implementacao, permitir somente valor_final na interface.

10. Corrigir o versionamento dos planos

Salvar qualquer configuracao cria um novo plano, migra embaixadores do plano anterior e mantem o plano antigo ativo. O banco atual ja possui dois planos ativos sem valid_to.

- 1 Separar configuracoes gerais de Publicar nova versao do plano.
- 2 Criar versao somente quando niveis, percentuais ou base mudarem.
- 3 Encerrar o plano anterior com valid_to e status inativo.
- 4 Mostrar quantos embaixadores serao migrados antes da publicacao.
- 5 Permitir vigencia futura e manter pedidos historicos no plano congelado.

Evidencia: migration 20260718191617, linhas 335-379.

P1 -
PAGAMENTOS

11. Criar fluxo seguro para alteracao de Pix

Quando a aprovacao e exigida, o sistema apenas bloqueia a edicao; nao existe solicitacao. Quando e permitida, uma conta comprometida pode alterar a chave antes do repasse.

- Criar solicitacoes de alteracao com chave anterior mascarada, nova chave protegida, status e aprovador.
- Exigir reautenticacao e, preferencialmente, MFA/OTP.
- Notificar o contato anterior do embaixador.
- Aplicar periodo de seguranca de 24 a 48 horas.
- Bloquear pagamentos durante alteracao pendente.
- Validar formato da chave e evitar texto completo em logs.

12. Criar lotes, conciliacao e estornos

Registrar pagamento hoje ja marca as comissoes como pagas. Nao existe confirmacao bancaria obrigatoria, falha de transferencia ou ledger de estorno.

Estado	Uso
rascunho	Lote em preparacao
aprovado	Valores e Pix conferidos
processando	Transferencia iniciada
pago	Pix confirmado
falhou	Transferencia nao concluida
cancelado / estornado	Operacao anulada ou revertida

- Marcar a comissao como paga somente depois da confirmacao do Pix.
- Exigir identificador bancario ou comprovante.
- Criar lancamento negativo para estornos; nao editar o valor original.
- Carregar saldo negativo para a proxima competencia quando necessario.
- Separar preparar lote de confirmar pagamento.

**P1 -
QUALIDADE**

13. Atualizar testes e criar CI financeiro

As suites SQL existentes refletem partes antigas do esquema: limite de tres niveis, unicidade sem commission_type e colunas antigas. O lint tambem falha atualmente com dois erros em LandingPage.tsx.

Cobertura obrigatoria

- Candidato para embaixador ativo e retomada de provisionamento.
- Edicao de pedido antes e depois do congelamento.
- Ativacao mensal, tolerancia, cancelamento e override.
- Indicador original inativo e disputas de atribuicao.
- Pagamento minimo, falha de Pix, estorno e concorrancia.
- Planos de um a dez niveis e bonus da primeira compra.
- Usuario bloqueado tentando usar sessao antiga.

Pipeline minimo

- 1 Lint e typecheck.
- 2 Build Next.js.
- 3 Banco limpo com todas as migrations.
- 4 Testes SQL financeiros e de RLS.
- 5 Testes end-to-end dos fluxos de venda, ativacao e pagamento.

**P2 - CONSOLID
ACAO**

14. Consentimento e protecao de dados

Todo comprador pode receber um cadastro adicional em ambassadors. A adesao deve ser clara e comprovavel.

- Checkbox de adesao ao programa, separado da compra.
- Termos versionados com data de aceite.
- Consentimento separado para comunicacoes.
- Opcao de comprar sem se tornar candidato.
- Politica de retencao para visitas, auditoria e dados de candidatos.
- Mascaramento de telefone e minimizacao de dados na rede.

15. Antifraude no checkout publico

- CAPTCHA ou Turnstile.
- Rate limit por IP hash, sessao, codigo, telefone, CPF e idempotency key.
- Deteccao de volume anormal por codigo de embaixador.
- Rejeicao explicita quando a visita nao for gravada.
- Retencao e limpeza de visitas antigas.

16. Observabilidade operacional

- Candidatos sem usuario e provisionamentos com falha.
- Embaixador ativo sem profile ou profile ativo com embaixador bloqueado.
- Pedido cujo total diverge do snapshot.
- Comissao parada por entrega, pagamento ou qualificacao.
- Alteracao recente de Pix e pagamentos abaixo do minimo.
- Indicador inativo com rede ativa e planos sem encerramento.
- Logs estruturados com correlation_id e alertas de falhas criticas.

17. Rede dinamica e experiencia

- Trocar as tres consultas fixas de Minha Rede por RPC recursiva baseada no plano.
- Pagar redes grandes e retornar somente campos necessarios.
- Usar a mesma fonte de plano na rede, calculadora e dashboard.
- Mostrar barra de progresso da ativacao mensal.
- Explicar por que cada comissao esta aguardando.
- Mostrar competencia prevista e avisos de Pix.
- Criar onboarding guiado e disponibilizar materiais oficiais.

18. Ordem recomendada de execucao

Fase 1 - integridade e seguranca

- 1 Provisionamento e ativacao idempotentes.
- 2 Bloqueio de status ativo sem user_id/profile.
- 3 Congelamento financeiro e momento correto da comissao.
- 4 Autorizacao centralizada do portal e sessao bloqueada.
- 5 Motor de ativacao mensal.
- 6 Testes financeiros minimos.

Fase 2 - regras comerciais e financeiro

- 1 Politica unica de atribuicao e cookie dinamico.
- 2 Base de comissao.
- 3 Versionamento de planos.
- 4 Fluxo de alteracao de Pix.
- 5 Lotes, conciliacao e estornos.

Fase 3 - escala e experiencia

- 1 Consentimento e retencao.
- 2 Protecao contra abuso.
- 3 Observabilidade e alertas.
- 4 Rede dinamica.
- 5 UX, notificacoes e materiais.

19. Decisoess comerciais antes do desenvolvimento

DECISOES OBRIGATORIAS A implementacao deve comecar somente depois de a Bryza definir formalmente as quatro regras abaixo. Sem isso, o risco e automatizar uma politica que precisara ser refeita.

Decisao	Pergunta que precisa ser respondida
Ativacao mensal	O que acontece com a comissao de quem nao cumpre R\$ 79?
Atribuicao	First-touch, last-touch ou permanente depois da primeira compra?
Adesao	Todo comprador vira candidato ou precisa aceitar participar?
Congelamento	Em que momento o pedido deixa de poder alterar a comissao?

20. O que nao deve ser feito

- Nao corrigir candidatos automaticos apenas adicionando um botao Ativar.
- Nao implementar ativacao mensal apagando comissoes.
- Nao editar valores historicos de comissao para corrigir divergencias.
- Nao usar service_role como substituto de RLS ou autorizacao.
- Nao permitir alteracao de Pix sem reautenticacao e trilha de auditoria.
- Nao publicar novo plano a cada alteracao de mensagem ou configuracao geral.
- Nao escalar marketing antes de testes de concorrancia e idempotencia.

Referencias tecnicas principais

- Supabase - Service role e RLS: https://supabase.com/docs/guides/troubleshooting/why-is-my-service-role-key-client-getting-rls-errors-or-not-returning-data-7_1K9z
- Supabase - User sessions: <https://supabase.com/docs/guides/auth/sessions>
- Supabase - Row Level Security: <https://supabase.com/docs/guides/database/postgres/row-level-security>
- Supabase - Database functions e privilegios: <https://supabase.com/docs/guides/database/functions>

Fontes locais revisadas

- supabase/migrations/20260718044648_amb_multilevel_scheduling_commissions.sql
- supabase/migrations/20260718191617_ambassador_program_scalable_settings.sql
- supabase/migrations/20260718195356_first_purchase_referral_bonus.sql
- src/app/api/embaixadores/route.ts
- src/app/embaixadores/actions.ts
- src/app/embaixador/actions.ts
- src/lib/referral/cookie.ts
- scratch/test_amb_portal_security_suite.sql
- scratch/test_multilevel_scheduling_commissions.sql
- scratch/test_referral_tracking_security_suite.sql

PROXIMO PASSO RECOMENDADO Transformar os itens PO em especificacao tecnica e implementar em migrations pequenas, testadas e reversiveis, com validacao em ambiente de homologacao antes de qualquer uso financeiro real.